

AI Customer Analytics Data Governance Policy

Student version | Policy document for conversion into Policy-as-Code

Policy metadata	Value
Policy ID	AI-CA-DG-001
Policy name	AI Customer Analytics Data Governance Policy
Version	1.0
Classification	Internal
Policy owner	Customer Analytics & Data Governance
Applies to	Customer analytics, segmentation, prediction, experimentation and AI/ML datasets
Review cycle	Annual or upon material change to customer data, AI or data governance requirements

1. Purpose

This policy defines mandatory requirements for identifying, classifying, restricting and governing customer data used in artificial intelligence, machine learning, analytics and experimentation activities.

2. Scope

This policy applies to customer datasets used for analytics or AI purposes, including raw extracts, curated datasets, feature tables, labelled data, test and validation data, event logs, customer feedback, model inputs and derived datasets.

3. Policy Objective

Customer data must be assessed before use. Restricted or high-risk customer information must be flagged. Data that violates an applicable rule must not be used for analytics or AI processing unless an approved exception is recorded.

4. Definitions

Term	Policy definition
Customer data	Information relating to an identifiable or reasonably identifiable customer.
Direct identifier	A data item that can identify a customer on its own.
Indirect identifier	A data item that may identify a customer when combined with other attributes.
Restricted data	Customer information requiring additional controls because of its sensitivity or potential impact.
Analytics dataset	Any dataset used to analyse, segment, predict or improve customer-related outcomes.
Flagged record	A record where one or more policy rules identify restricted or potentially identifying customer information.
Remediation	Action taken to remove, mask, tokenise, generalise or otherwise reduce the data risk before use.

5. Customer Data Classification Catalogue

5.1 Direct customer identifiers

The following fields are treated as customer-identifying information when present in analytics or AI datasets and must be flagged.

Rule ID	Data type	Examples	Required policy outcome
CID-01	Customer name	first_name, last_name, full_name, customer_name	Flag record
CID-02	Personal email	email, personal_email, contact_email	Flag record
CID-03	Phone number	mobile, telephone, phone_number	Flag record
CID-04	Home or delivery address	address, home_address, delivery_address, postcode	Flag record
CID-05	Government-issued identifier	national_id, tax_id, licence_number	Block until removed or approved
CID-06	Customer account number	account_number, customer_account_id where externally linkable	Block until removed or approved
CID-07	Payment information	bank_account, card_number, payment_token where linkable	Block until removed or approved
CID-08	Online or device identifier	IP_address, device_id, cookie_id, advertising_id	Flag record

5.2 Restricted customer data

The following categories must be blocked unless a documented approval and appropriate control justification exists.

Rule ID	Restricted data type	Examples	Required policy outcome
RC-01	Financial difficulty or vulnerability	arrears_status, vulnerability_flag, financial_hardship	Block record
RC-02	Health-related customer information	medical_support, health_condition, disability_information	Block record
RC-03	Precise location history	gps_trace, exact_location_history, precise_coordinates	Block record
RC-04	Authentication or security secrets	password, security_answer, authentication_secret	Block record
RC-05	Fraud investigation information	fraud_case_notes, investigation_details, suspicious_activity_notes	Block record
RC-06	Biometric information	voiceprint, face_template, fingerprint_template	Block record

5.3 Indirect identifiers and combination rules

Some fields may not identify a customer on their own but can create identification or customer-risk concerns when combined. The following combinations must be flagged.

Rule ID	Combination rule	Required policy outcome
CCID-01	Full name + date of birth	Flag record
CCID-02	Full name + home address or postcode	Flag record
CCID-03	Customer ID + account balance or transaction event	Flag record
CCID-04	Email address + device ID	Flag record
CCID-05	Date of birth + postcode + gender	Flag record
CCID-06	Customer ID + complaint or support case details	Flag record
CCID-07	Location history + timestamp + customer identifier	Flag record
CCID-08	Free-text feedback containing customer identifiers or sensitive details	Flag record

6. Mandatory Policy Requirements

Rule ID	Policy requirement	Policy statement
DG-01	Pre-use data scan	Customer datasets must be scanned for identifying and restricted data before analytics or AI use.
DG-02	Record-level flagging	Each record containing direct, restricted or combination-based customer data must be flagged.
DG-03	Identifier handling	Direct identifiers must be removed, masked, tokenised or replaced before approval for general analytics use.
DG-04	Restricted data handling	Restricted customer data must be blocked unless documented approval and control justification exists.
DG-05	Combination handling	Records matching combination rules must be reviewed and remediated before use.
DG-06	Free-text scanning	Comments, complaints, notes, descriptions and feedback must be scanned for identifying or restricted information.
DG-07	Purpose limitation	Customer data must only be used for the approved analytics or AI purpose for which access was granted.
DG-08	Approved dataset output	Only records with no unresolved policy findings may be included in the approved dataset.
DG-09	Exception handling	Exceptions must be documented, risk-assessed, time-bound and approved by the designated data governance authority.
DG-10	Audit trail	Scan results, triggered rules, decisions, remediation status and approvals must be retained for audit purposes.

7. Dataset Decision Outcomes

Decision	Meaning	Required action
PASS	No restricted or suspected customer data has been detected.	Record may be included in the approved analytics dataset.
FLAG	Direct or combination-based customer-identifying data has been detected.	Record must be remediated before general analytics or AI use.
BLOCK	Restricted data or a high-risk identifier has been detected.	Record must be excluded unless an approved exception exists.
EXCEPTION APPROVED	Documented approval permits controlled use of the record.	Use only under the approved conditions and retain audit evidence.

8. Remediation Requirements

Remediation method	Policy expectation
Removal	Delete the customer data field or remove the record where the information is not required.
Masking	Replace part of the value while preserving limited analytical utility, where appropriate.
Tokenisation	Replace a customer identifier with a non-identifying token.
Generalisation	Reduce precision, such as replacing exact location with region or age with an age band.
Aggregation	Combine records or values so individual customers cannot reasonably be inferred.
Anonymisation	Transform data so customers are no longer reasonably identifiable.

9. Minimum Evidence Required

Evidence item	Requirement
Dataset name	Name and version of the dataset assessed.
Scan date	Date when the dataset was scanned.
Triggered rule IDs	List of policy rules triggered by each flagged or blocked record.
Decision	PASS, FLAG, BLOCK or EXCEPTION APPROVED.
Remediation status	Not required, pending, completed or exception approved.
Purpose / use case	Approved analytics or AI purpose for which the dataset is being used.
Reviewer or approver	Named reviewer or approval reference where required.

10. Non-compliance

Datasets with unresolved customer-data findings must not be used for unapproved analytics, AI or experimentation. Non-compliance may result in suspension of dataset access, removal of system access, escalation to the data owner, remediation requirements or other action determined by the organisation.

11. Policy Review

This policy must be reviewed at least annually or when there is a material change to customer data use, AI governance, analytics practices, security controls or regulatory requirements.

Document control

Document control

Version	Date	Summary of change	Owner
1.0	07 September 2026	Initial student version for customer analytics data governance policy-as-code exercise.	Customer Analytics & Data Governance

Policy-as-Code conversion notes

This policy is intentionally structured similarly to the reference policy so it can be used as a second input document for a generic policy extraction and Rego compilation pipeline. It contains direct field rules, restricted-data rules, combination rules, mandatory requirements, decision outcomes, remediation methods and evidence requirements.

Rule families use distinct identifiers (CID, RC, CCID and DG) so the resulting normalized policy can be compared against another department's policy without relying on the original rule IDs.